SECURITY ENGINEERING — HANDS-ON LAB

CrowdStrike Falcon API Detection & Triage

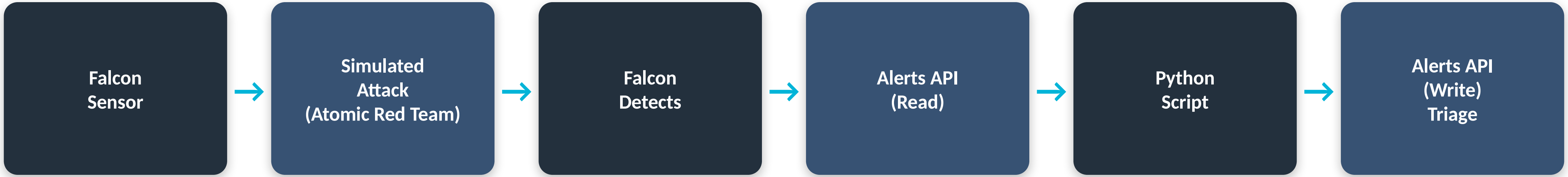
Sensor → API Client → Real Detection → Automated Triage

David Rufino Botte | Senior Desktop Engineer

github.com/davidrufinobotte/security-engineering-labs

HOW IT WORKS

From endpoint sensor to automated triage



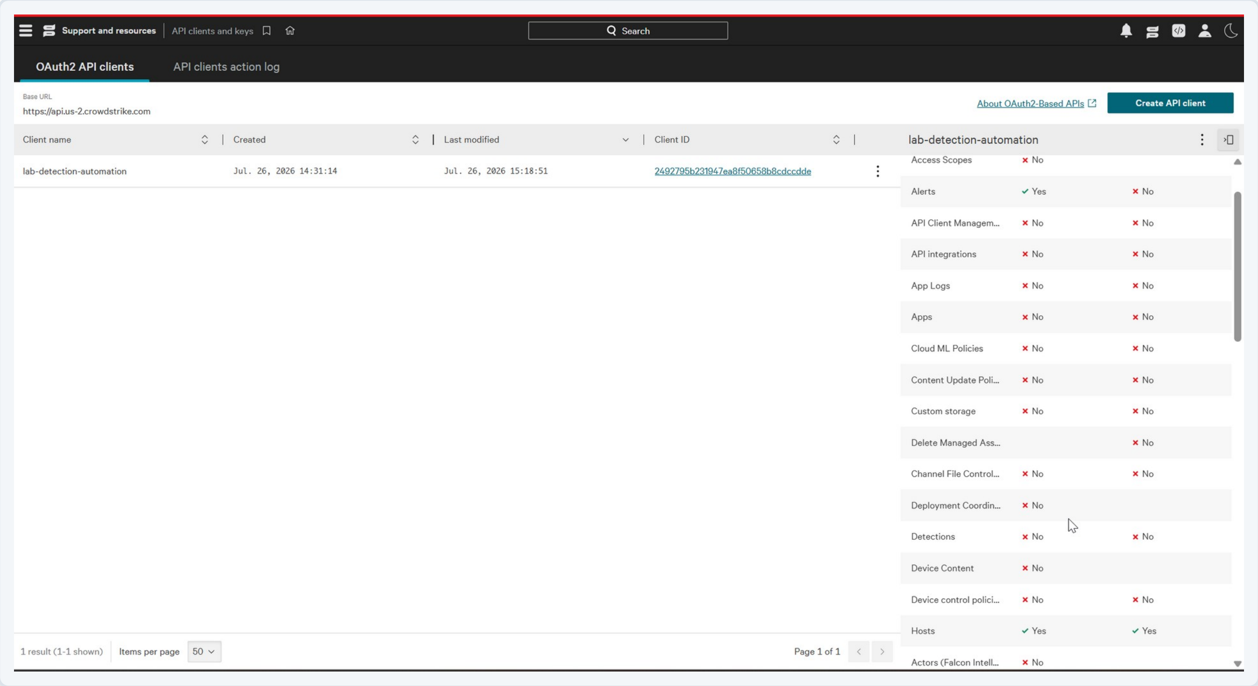
A safe, authorized simulated attack triggers real Falcon detections. A Python script reads them via API, then writes back a status update and comment — closing the loop from detection to response.

01

ACCESS SETUP

A Least-Privilege API Client

- Created a dedicated OAuth2 API client (lab-detection-automation)
- Scoped to exactly what the project needs: Alerts and Hosts — nothing else
- Same least-privilege principle applied earlier in the Entra ID + Sentinel lab

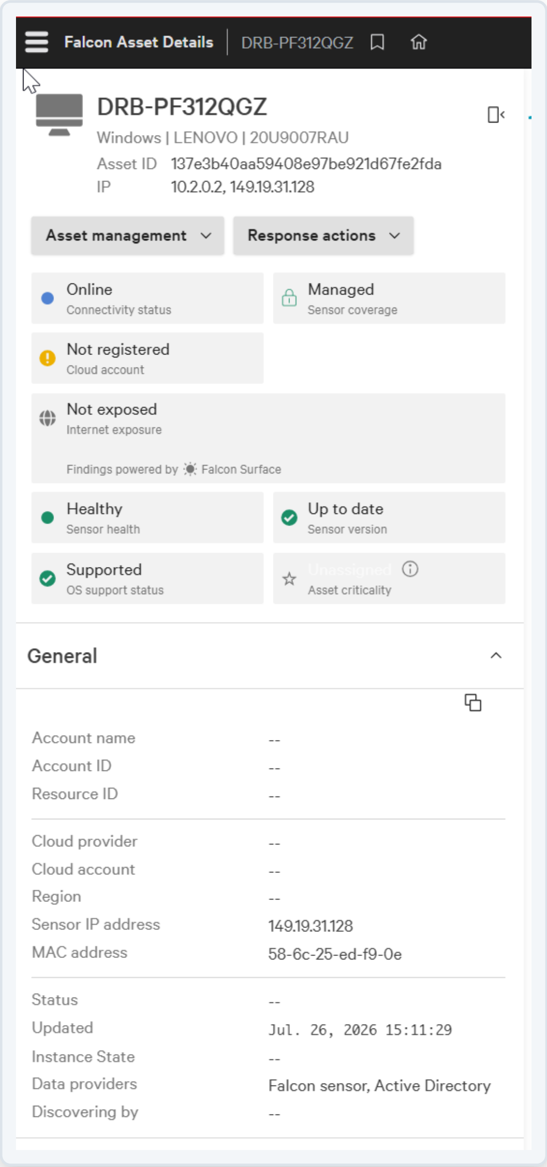


02

FOUNDATION

Sensor Deployed & Reporting

- Falcon sensor installed on a dedicated test laptop
- Confirmed online, managed, healthy, and up to date within minutes
- This is the data source everything downstream depends on

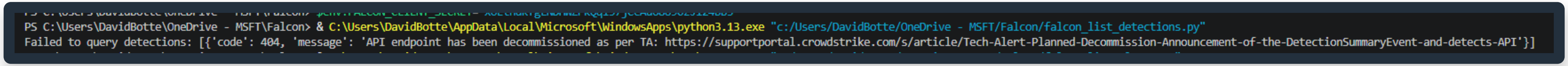


03

REAL PROBLEM #1

Hit a Decommissioned API

- First script used FalconPy's classic Detects service class — the industry-standard starting point
- CrowdStrike retired this API entirely; the request failed with a clear 404



04

REAL PROBLEM #2

Migrated API, Wrong Scope

- Rewrote the script against the current Alerts API — but the client's old scope name didn't carry over
- 403 access denied — fixed by granting the correct Alerts: Read scope

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_list_alerts.py"
Failed to retrieve alerts: [{'code': 403, 'message': 'access denied, scope not permitted'}]
```

05

VALIDATION

Confirmed Working — Before Any Data

- With auth and scope fixed, the script ran cleanly and correctly reported zero alerts
- Proves the pipeline works end to end before relying on it to catch something real

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_list_alerts.py"
No alerts found yet. This is expected on a fresh trial with no test activity.
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_list_alerts.py"
No alerts found yet. This is expected on a fresh trial with no test activity.
```

GENERATING A REAL SIGNAL

Why EICAR didn't work — and what did

EICAR: no detection.

Falcon is a behavior-based EDR — a static test file sitting on disk, never executed, simply doesn't trigger it. Expected, not a misconfiguration.

Atomic Red Team: real detection.

Ran MITRE technique T1053.005 (Scheduled Task persistence) — a safe, reversible simulation of real attacker behavior, with automatic cleanup after.

06

RESULT

10 Alerts, Multiple Detection Layers

- One safe technique triggered detections across Execution, Machine Learning, and Malware categories — confirming several of Falcon's engines are active, not just one signature check

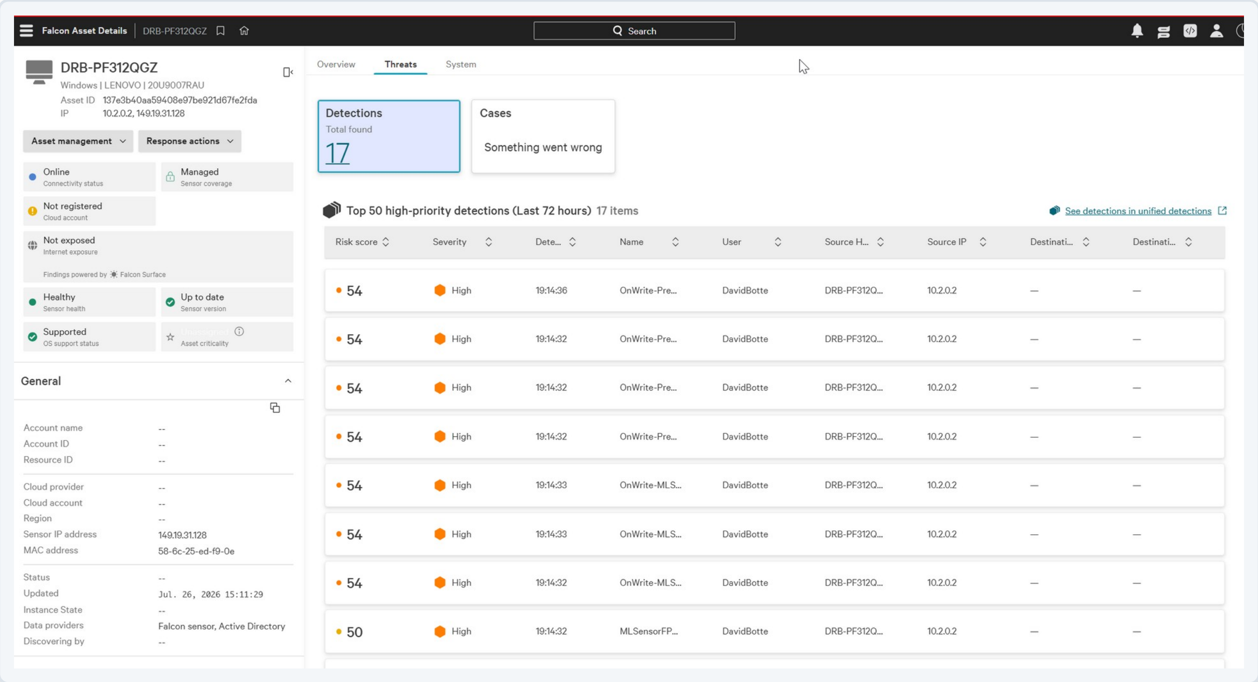
```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_list_alerts.py"

Found 10 alert(s):

Hostname             Severity   Status          Created                    Tactic
----------------------------------------------------------------------------------------------
DRB-PF312QGZ         Medium     new             2026-07-26T07:14:37.215087618Z Execution
DRB-PF312QGZ         Medium     new             2026-07-26T07:14:37.215720815Z Execution
DRB-PF312QGZ         High       new             2026-07-26T07:14:36.034115457Z Machine Learning
DRB-PF312QGZ         Low        new             2026-07-26T07:14:36.031553007Z Malware
DRB-PF312QGZ         Medium     new             2026-07-26T07:14:36.022120312Z Machine Learning
DRB-PF312QGZ         High       new             2026-07-26T07:14:33.529206329Z Machine Learning
DRB-PF312QGZ         High       new             2026-07-26T07:14:33.527696006Z Machine Learning
DRB-PF312QGZ         Low        new             2026-07-26T07:14:32.657121195Z Malware
DRB-PF312QGZ         High       new             2026-07-26T07:14:32.656817272Z Machine Learning
DRB-PF312QGZ         Low        new             2026-07-26T07:14:32.649714135Z Malware
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon>
```

07

CROSS-CHECK

Confirmed in the Console Too

- Cross-checked the API results against the Falcon console directly on the host
- 17 total detections found — the API view and the console view agree
- Good practice: never trust a script's output alone when a source of truth is one click away



08

REAL PROBLEMS #3 & #4

Closing the Loop Took Two More Fixes

- Extended the script to update and close alerts via API — not just read them

Wrong parameter name (ids vs. composite_ids)

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_triage_alerts.py"
Found 10 alert(s) to triage.

Failed to update alerts: [{'code': 400, 'message': 'at least one identifier should be present in the request'}]
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon>
```

Wrong status value — fixed using the exact values from the API's own error message

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_triage_alerts.py"
Found 10 alert(s) to triage.

Failed to update alerts: [{'code': 400, 'message': 'invalid status for update_status action param. must be one of ["closed:A closed alert", "new:A new alert", "in_progress:An in progress alert", "reopened:A reopened alert"]'}]
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon>
```

09

OUTCOME

Automated Triage, Confirmed

- All 10 alerts closed via API with a status update and an audit comment explaining the authorized test — the same closing discipline used in the Sentinel lab, done here through code

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> & C:\Users\DavidBotte\AppData\Local\Microsoft\WindowsApps\python3.13.exe "c:/Users/DavidBotte/OneDrive - MSFT/Falcon/falcon_triage_alerts.py"
Found 10 alert(s) to triage.

Successfully triaged 10 alert(s):
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10072546568-10417-642320
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10072546568-10417-626448
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:8884985515-10127-613904
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-10127-613392
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-5734-593936
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-4748-605200
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-5738-609296
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-5733-532752
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-5733-546064
  - 7391a4d69e3d4bb2aa3ccb993fedd55f:ind:137e3b40aa59408e97be921d67fe2fda:10034639130-4748-482576
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon>
```

API client updated with write access, scoped only to what triage required

10

GOING FURTHER

Testing Across Multiple Tactics

- Ran two more Atomic Red Team techniques, covering different MITRE tactics than the original test
- T1082 (Discovery): ran cleanly, no alert — expected, since a native systeminfo command alone isn't distinct enough to flag
- T1112 (Defense Evasion): blocked by Falcon's prevention layer AND still generated a High severity alert — prevention and detection working together, not just one or the other

```
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon> python falcon_list_alerts.py

Found 10 alert(s):

Hostname             Severity   Status          Created                    Tactic
-----------------------------------------------------------------------------------------------
DRB-PF312QGZ         High       new             2026-08-01T01:15:54.304645005Z Defense Evasion
DRB-PF312QGZ         Informational new             2026-08-01T01:15:54.3011847Z Execution
DRB-PF312QGZ         Informational new             2026-08-01T01:12:54.635607071Z Execution
DRB-PF312QGZ         Medium     new             2026-08-01T00:51:06.189747275Z Execution
DRB-PF312QGZ         Medium     new             2026-08-01T00:51:06.154824638Z Execution
DRB-PF312QGZ         Medium     new             2026-08-01T00:51:05.220115589Z Machine Learning
DRB-PF312QGZ         High       new             2026-08-01T00:51:05.210007623Z Machine Learning
DRB-PF312QGZ         Low        new             2026-08-01T00:51:05.187563568Z Malware
DRB-PF312QGZ         Low        new             2026-08-01T00:51:05.186290972Z Malware
DRB-PF312QGZ         High       new             2026-08-01T00:51:05.184135574Z Machine Learning
PS C:\Users\DavidBotte\OneDrive - MSFT\Falcon>
```

WHAT THIS DEMONSTRATES

Skills applied in this lab

- **EDR & API Integration**

  CrowdStrike Falcon, FalconPy SDK, OAuth2 authentication

- **Adversary Simulation**

  MITRE ATT&CK technique execution via Atomic Red Team

- **Real API Debugging**

  Diagnosed and fixed 4 distinct real errors, not scripted ones

- **Automated Triage & Response**

  Closed the loop: read, triaged, and contained hosts via API — with safety-first dry-run design

- **Least Privilege**

  Scoped API client access to exactly what each task needed

- **Verification Discipline**

  Cross-checked script output against the console directly

David Rufino Botte

github.com/davidrufinobotte/security-engineering-labs